

Passive Subdomain Enumeration

Subdomain enumeration refers to mapping all available subdomains within a domain name. It increases our attack surface and may uncover hidden management backend panels or intranet web applications that network administrators expected to keep hidden using the "security by obscurity" strategy. At this point, we will only perform passive subdomain enumeration using third-party services or publicly available information. Still, we will expand the information we gather in future active subdomain enumeration activities.

VirusTotal

VirusTotal maintains its DNS replication service, which is developed by preserving DNS resolutions made when users visit URLs given by them. To receive information about a domain, type the domain name into the search bar and click on the "Relations" tab.

The screenshot shows the VirusTotal interface with the 'Relations' tab selected. It displays two sections: 'Passive DNS Replication' and 'Subdomains'.

Passive DNS Replication

Date resolved	Detections	Resolver	IP
2021-10-06	0 / 86	VirusTotal	157.240.205.35
2021-10-01	0 / 85	QiAnXin RedDrip	104.31.143.88
2021-10-01	0 / 85	QiAnXin RedDrip	185.60.216.169
2021-09-30	0 / 85	QiAnXin RedDrip	199.96.63.75
2021-09-30	0 / 85	QiAnXin RedDrip	179.60.193.9
2021-09-30	0 / 85	VenusEye Sandbox	111.243.214.169
2021-09-29	0 / 85	QiAnXin RedDrip	31.13.85.2
2021-09-29	0 / 87	QiAnXin RedDrip	150.107.3.176
2021-09-29	0 / 86	QiAnXin RedDrip	124.11.210.175
2021-09-29	0 / 86	QiAnXin RedDrip	202.160.130.52

Subdomains

Subdomain	Detections	IP 1	IP 2	IP 3	...
nl-nl.facebook.com	0 / 86	157.240.205.1	157.240.222.16	157.240.232.15	...
upload.facebook.com	0 / 86	157.240.205.1	157.240.224.3	157.240.232.15	...
zh-tw.facebook.com	0 / 86	157.240.7.20	157.240.205.1	157.240.229.17	...
lm.facebook.com	0 / 86	157.240.205.36	157.240.224.36	157.240.7.36	...
static.facebook.com	0 / 86	157.240.205.1	31.13.65.1	157.240.30.18	...
api.facebook.com	0 / 86	157.240.205.1	31.13.82.1	157.240.236.15	...
de-de.facebook.com	0 / 86	157.240.205.1	157.240.236.15	157.240.7.20	...
zh-cn.facebook.com	0 / 86	157.240.205.1	157.240.236.15	157.240.216.16	...

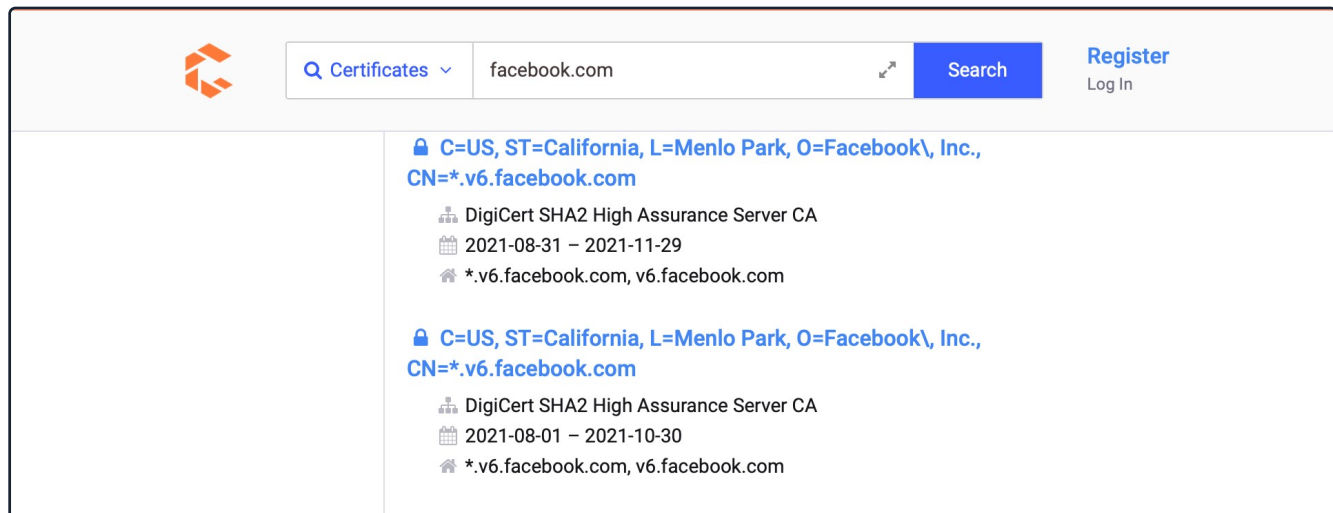
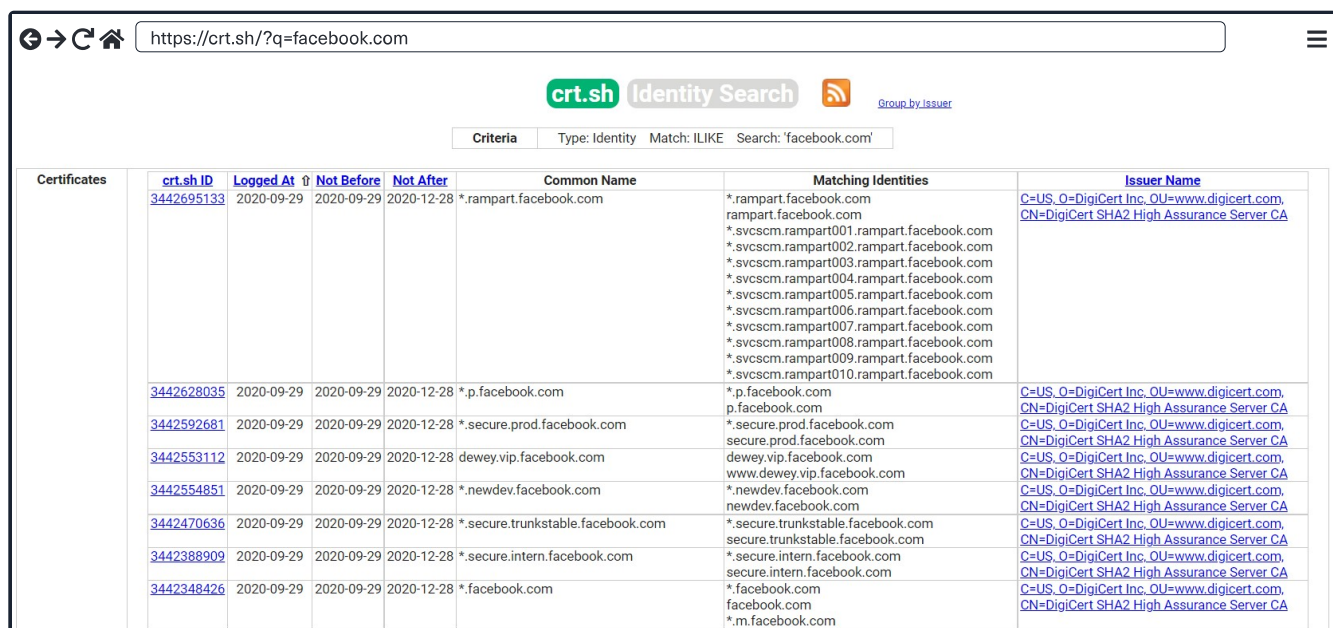
Certificates

Another interesting source of information we can use to extract subdomains is SSL/TLS certificates. The main reason is Certificate Transparency (CT), a project that requires every SSL/TLS certificate issued by a Certificate Authority (CA) to be published in a publicly accessible log.

We will learn how to examine CT logs to discover additional domain names and subdomains for a target organization using two primary resources:

- <https://censys.io>
- <https://crt.sh>

We can navigate to <https://search.censys.io/certificates> or <https://crt.sh> and introduce the domain name of our target organization to start discovering new subdomains.

Certificates	crt.sh ID	Logged At	Not Before	Not After	Common Name	Matching Identities	Issuer Name
	3442695133	2020-09-29	2020-09-29	2020-12-28	*.rampart.facebook.com	*.rampart.facebook.com rampart.facebook.com *.svcsdm.rampart001.rampart.facebook.com *.svcsdm.rampart002.rampart.facebook.com *.svcsdm.rampart003.rampart.facebook.com *.svcsdm.rampart004.rampart.facebook.com *.svcsdm.rampart005.rampart.facebook.com *.svcsdm.rampart006.rampart.facebook.com *.svcsdm.rampart007.rampart.facebook.com *.svcsdm.rampart008.rampart.facebook.com *.svcsdm.rampart009.rampart.facebook.com *.svcsdm.rampart010.rampart.facebook.com	C=US, O=DigiCert Inc, OU=www.digicert.com, CN=DigiCert SHA2 High Assurance Server CA
	3442628035	2020-09-29	2020-09-29	2020-12-28	*.p.facebook.com	*.p.facebook.com p.facebook.com	C=US, O=DigiCert Inc, OU=www.digicert.com, CN=DigiCert SHA2 High Assurance Server CA
	3442592681	2020-09-29	2020-09-29	2020-12-28	*.secure.prod.facebook.com	*.secure.prod.facebook.com secure.prod.facebook.com	C=US, O=DigiCert Inc, OU=www.digicert.com, CN=DigiCert SHA2 High Assurance Server CA
	3442553112	2020-09-29	2020-09-29	2020-12-28	*.dewey.vip.facebook.com	dewey.vip.facebook.com www.dewey.vip.facebook.com	C=US, O=DigiCert Inc, OU=www.digicert.com, CN=DigiCert SHA2 High Assurance Server CA
	3442554851	2020-09-29	2020-09-29	2020-12-28	*.newdev.facebook.com	*.newdev.facebook.com newdev.facebook.com	C=US, O=DigiCert Inc, OU=www.digicert.com, CN=DigiCert SHA2 High Assurance Server CA
	3442470636	2020-09-29	2020-09-29	2020-12-28	*.secure.trunkstable.facebook.com	*.secure.trunkstable.facebook.com secure.trunkstable.facebook.com	C=US, O=DigiCert Inc, OU=www.digicert.com, CN=DigiCert SHA2 High Assurance Server CA
	3442388909	2020-09-29	2020-09-29	2020-12-28	*.secure.intern.facebook.com	*.secure.intern.facebook.com secure.intern.facebook.com	C=US, O=DigiCert Inc, OU=www.digicert.com, CN=DigiCert SHA2 High Assurance Server CA
	3442348426	2020-09-29	2020-09-29	2020-12-28	*.facebook.com	*.facebook.com facebook.com *.m.facebook.com	C=US, O=DigiCert Inc, OU=www.digicert.com, CN=DigiCert SHA2 High Assurance Server CA

Although the website is excellent, we would like to have this information organized and be able to combine it with other sources found throughout the information-gathering process. Let us perform a curl request to the target website asking for a JSON output as this is more manageable for us to process. We can do this via the following commands:

Certificate Transparency

Certificate Transparency

```

dbcypn@htb[/htb]$ export TARGET="facebook.com"
dbcypn@htb[/htb]$ curl -s "https://crt.sh/?q=${TARGET}&output=json" | jq -r '[] | "\(.name_value)\n\(.common_name)"'

```

Certificate Transparency

```

dbcypn@htb[/htb]$ head -n20 facebook.com_crt.sh.txt

```

```
*.adtools.facebook.com
*.ak.facebook.com
*.ak.fbcdn.net
*.alpha.facebook.com
*.assistant.facebook.com
*.beta.facebook.com
*.channel.facebook.com
*.cinyour.facebook.com
*.cinyourrc.facebook.com
*.connect.facebook.com
*.cstools.facebook.com
*.ctscan.facebook.com
*.dev.facebook.com
*.dns.facebook.com
*.extern.facebook.com
*.extools.facebook.com
*.f--facebook.com
*.facebook.com
*.facebookcorewwwi.onion
*.facebookmail.com
```

```
curl -s
```

Issue the request with minimal output.

```
https://crt.sh/?q=<DOMAIN>&output=json
```

Ask for the json output.

```
jq -r '.[0]' "\(.name_value)
\n\(.common_name)"
```

Process the json output and print certificate's name value and common name one per line.

```
sort -u
```

Sort alphabetically the output provided and removes duplicates.

We also can manually perform this operation against a target using OpenSSL via:

Certificate Transparency

```
dbcypn@htb[/htb]$ export TARGET="facebook.com"
dbcypn@htb[/htb]$ export PORT="443"
dbcypn@htb[/htb]$ openssl s_client -ign_eof 2>/dev/null <<<'HEAD / HTTP/1.0\r\n\r\n' -connect "${TARGET}:${PORT}"

*.facebook.com
*.facebook.net
*.fbcdn.net
*.fbstatic.com
*.m.facebook.com
*.messenger.com
*.xx.fbcdn.net
*.xy.fbcdn.net
*.xz.fbcdn.net
facebook.com
messenger.com
```

Automating Passive Subdomain Enumeration

We have learned how to acquire helpful information from our target organization, like subdomains, naming patterns, alternate TLDs, IP ranges, etc., using third-party services without interacting directly with their infrastructure or relying on automated tools. Now, we will learn how to enumerate subdomains using tools and previously obtained information.

TheHarvester

[TheHarvester](#) is a simple-to-use yet powerful and effective tool for early-stage penetration testing and red team engagements. We can use it to gather information to help identify a company's attack surface. The tool collects **emails**, **names**, **subdomains**, **IP addresses**,

Baidu	Baidu search engine.
Bufferoverun	Uses data from Rapid7's Project Sonar - www.rapid7.com/research/project-sonar/
Crtsh	Comodo Certificate search.
Hackertarget	Online vulnerability scanners and network intelligence to help organizations.
Otx	AlienVault Open Threat Exchange - https://otx.alienvault.com
Rapiddns	DNS query tool, which makes querying subdomains or sites using the same IP easy.
Sublist3r	Fast subdomains enumeration tool for penetration testers
Threatcrowd	Open source threat intelligence.
Threatminer	Data mining for threat intelligence.
Trello	Search Trello boards (Uses Google search)
Urlscan	A sandbox for the web that is a URL and website scanner.
Vhost	Bing virtual hosts search.
Virustotal	Domain search.
Zoomeye	A Chinese version of Shodan.

```
TheHarvester

dbcyp0n@htb[/htb]$ cat sources.txt

baidu
bufferoverun
crtsh
hackertarget
otx
projecdiscovery
rapiddns
sublist3r
threatcrowd
trell0
urlscan
vhost
virustotal
zoomeye
```

[illegible]

When the process finishes, we can extract all the subdomains found and sort them via the following command:

Now we can merge all the passive reconnaissance files via:

So far, we have managed to find 11947 subdomains merging the passive reconnaissance result files. It is important to note here that there are many more methods to find subdomains passively. More possibilities are shown, for example, in the [OSINT: Corporate Recon](#) module.

Table of Contents

Information Gathering	✓
Passive Information Gathering	
📦 WHOIS	✓
📦 DNS	✓
Passive Subdomain Enumeration	✓

Passive Infrastructure Identification



Active Information Gathering

 Active Infrastructure Identification

 Active Subdomain Enumeration

 Virtual Hosts

Crawling

Putting it all Together

 Information Gathering - Web - Skills Assessment

My Workstation

O F F L I N E

 Start Instance

∞ / 1 spawns left